# Controles sobre las personas

## Introducción

Los controles sobre las personas tienen como objetivo gestionar los riesgos de seguridad de la información asociados al factor humano dentro de una organización. El capítulo establece medidas que abarcan todo el ciclo de relación de una persona con la organización: desde la comprobación de sus antecedentes antes de incorporarse, pasando por la definición de sus responsabilidades, su formación y el cumplimiento de las políticas de seguridad, hasta las obligaciones que permanecen después de finalizar o cambiar su relación laboral.

## Controles

### 6.1 Comprobación

Es un control preventivo el cual busca proteger las dimensiones de CID de la seguridad de la información.

Se basa en la comprobación de antecedentes de todos los candidatos al puesto de trabajo, la misma se debe hacer de acuerdo a las leyes, reglamentos y éticas aplicables, y proporcional a los requisitos laborales, los riesgos percibidos y al tipo de información que se accede. De esta forma, se garantiza que todos los candidatos sean adecuados al puesto para el que se los considera. Los controles deben realizarse de forma periódica dependiendo de la importancia de la función de cada persona.

Aquí es donde se utiliza el concepto “screening”, el cual significa búsqueda de antecedentes. Puede utilizarse en diferentes ambientes, como búsqueda de antecedentes médicos, pero en este contexto se busca verificar la aptitud de cada candidato para el puesto que se busca cubrir.

Si este método se quiere comenzar a implementar en una organización ya consolidada, es recomendable que no solo se realice sobre los candidatos a contratación, sino también, sobre el personal ya contratado o sobre los empleados que trabajan en la organización, pero pertenecen a un proveedor de servicio (debe estar incluido en los acuerdos contractuales entre la organización y el proveedor de servicio). Esto puede llevar al equipo a identificar posibles riesgos que no se hayan tenido en cuenta.

La verificación debe incluir:

A. Referencias satisfactorias.
B. Verificación del CV.
C. Confirmación de cualidades académicas o profesionales.
D. Comprobación de la identificación.
E. Verificación crediticia o de antecedentes penales.

Además, cuando se contrata una persona para un rol específico de seguridad:

F. Asegurarse si el candidato tiene la competencia necesaria para desempeñar el rol de seguridad.
G. Asegurarse si se puede confiar en él.

Si los controles no pueden completarse en tiempo y forma, se deben realizar ciertos retrasos (de incorporación, despliegue, acceso reducido, etc.) hasta que puedan hacerlo.

## 6.2 Términos y condiciones de contratación

Es un control preventivo el cual busca proteger las dimensiones de CID de la seguridad de la información.

Los acuerdos contractuales de empleo deben indicar las responsabilidades del personal y de la organización en materia de seguridad de la información, de manera que el personal tenga conocimiento pleno de estos para que pueda aceptarlos. Dichas obligaciones deben tener en cuenta las políticas de la empresa y las políticas específicas relevantes, aún así puede que hagan falta algunas aclaraciones como:

A. El personal al que se le dé acceso a información confidencial debería firmar los acuerdos de confidencialidad o de no revelación de información (NDA) de manera previa a darle acceso a dicha información y a otros activos asociados.
B. Las responsabilidades y derechos legales.
C. Las responsabilidades en materia de clasificación de la información y gestión de la información de la organización y de otros activos asociados.
D. Las responsabilidades de las partes interesadas del tratamiento de la información recibida.
E. Las acciones que tienen que tomarse si el personal hace caso omiso a los requisitos de seguridad de la organización.

Estos términos y condiciones deberían ser apropiados para la naturaleza y el alcance del acceso que tendrán a los activos de la organización asociados con los sistemas y servicios de información. Los términos y condiciones relativos a la seguridad de la información deberán revisarse cuando cambie la legislación, los reglamentos, la política de seguridad de la información o las políticas específicas.

Se puede utilizar un código de conducta para establecer las responsabilidades del personal en materia de seguridad de la información en relación con la confidencialidad, la protección de la información personal identificable, la ética, el uso apropiado de la información de la organización y otros activos asociados, así como la buena reputación de la organización.

## 6.3 Concienciación, educación y formación en seguridad de la información

La organización debería proporcionar al personal y a las partes interesadas pertinentes una adecuada concienciación, educación y formación en seguridad de la información, junto con actualizaciones periódicas sobre las políticas y procedimientos aplicables. Estas actividades deben adaptarse al puesto y a las responsabilidades de cada persona.

La organización debería establecer un programa de concienciación, educación y capacitación que se realice periódicamente. La formación inicial debería proporcionarse al

personal nuevo y también a quienes cambien de puesto cuando el nuevo rol implique requisitos de seguridad significativamente diferentes. La comprensión de los participantes debería evaluarse para determinar si la capacitación fue efectiva.

La concienciación puede realizarse mediante diferentes medios (presencial, por boletines, virtual, etc.), además, deben centrarse en responder “qué”, “cómo” y “por qué”, para que el personal pueda comprender el objetivo de la misma y sus efectos. Debe abarcar las responsabilidades individuales, las políticas y obligaciones aplicables, los procedimientos básicos de seguridad, la notificación de eventos y los recursos disponibles para recibir asesoramiento. Para los equipos técnicos, además, deben desarrollarse competencias específicas que permitan mantener el nivel de seguridad requerido en sistemas, dispositivos, aplicaciones y servicios.

La concientización y capacitación no solo debe esclarecer al personal sobre sus responsabilidades, políticas u obligaciones, sino que también es muy importante que se den a conocer los riesgos que pueden suceder en su área de trabajo. Dentro de estos riesgos pueden encontrarse ataques a la red de la información, los más comunes son phishing por ejemplo. Es importante saber prevenirlos, mitigarlos o, en el peor de los casos, detectarlos, contenerlos y recuperar el servicio.

La dirección debe tener compromiso con la seguridad de la información, ya que es la que provee recursos para que se lleve a cabo. Además, si no se cuenta con los recursos necesarios, es la organización la que debe ocuparse de adquirirlos.

## 6.4 Proceso disciplinario

La organización debería disponer de un proceso disciplinario formal, comunicado previamente al personal y a las partes interesadas pertinentes, que establezca las acciones que pueden tomarse ante una infracción de las políticas de seguridad de la información. Su propósito es que las personas comprendan las consecuencias de incumplir las políticas, disuadir futuras infracciones y permitir una respuesta adecuada cuando estas ocurran.

Antes de iniciar el proceso disciplinario debería verificarse que efectivamente se produjo una infracción. La respuesta debería ser gradual y considerar factores como la naturaleza y gravedad de la infracción, sus consecuencias, si fue intencionada o accidental, si se trata de una primera infracción o una reincidencia y si la persona había recibido la formación adecuada.

Las medidas disciplinarias deben considerar los requisitos legales, reglamentarios, contractuales y empresariales aplicables. Las violaciones deliberadas pueden requerir medidas inmediatas. Siempre que sea posible, la identidad de las personas sometidas a medidas disciplinarias debería protegerse de acuerdo con los requisitos aplicables.

Este es un control preventivo y correctivo que no solo busca proteger, sino que también responder frente a una infracción. Para promover el seguimiento de las normas, estatutos, etc., se puede plantear un sistema de recompensas para promover la seguridad de la información.

## 6.5 Responsabilidades ante la finalización o cambio

Las responsabilidades y obligaciones de seguridad de la información que continúen vigentes después de la finalización o cambio de empleo deberían estar definidas, comunicadas y ser aplicadas. El objetivo es proteger los intereses de la organización durante el proceso de desvinculación o modificación de las funciones de una persona.

Entre las obligaciones que pueden continuar después de la relación laboral se encuentran la confidencialidad de la información, la protección de la propiedad intelectual, los conocimientos obtenidos durante el empleo y las responsabilidades establecidas mediante acuerdos de confidencialidad. Estas obligaciones deberían estar contempladas en los términos y condiciones de empleo, contratos o acuerdos correspondientes.

Cuando una persona cambia de puesto, el proceso debería gestionarse como el cese de sus responsabilidades anteriores y el comienzo de las nuevas. Las responsabilidades de seguridad deben identificarse y transferirse a otra persona cuando corresponda, y los cambios deben comunicarse a las partes interesadas pertinentes. Este proceso también debería aplicarse al personal externo cuando finalice o cambie su relación contractual con la organización.

## 6.6 Acuerdos de confidencialidad o no divulgación

Los acuerdos de confidencialidad o no divulgación deberían identificar, documentar, revisar periódicamente y proteger las necesidades de información de la organización. Estos acuerdos deben ser firmados por el personal y por otras partes interesadas pertinentes y utilizar términos legalmente exigibles. Operan sobre la protección de la información, seguridad de los recursos humanos y la relación de la organización con los proveedores.

El contenido del acuerdo debería adecuarse al tipo de información que será manejada, su clasificación, el uso previsto y el nivel de acceso permitido. Entre otros aspectos, debería definir qué información debe protegerse, durante cuánto tiempo se mantiene la obligación de confidencialidad, las responsabilidades de los firmantes y las acciones necesarias para evitar una divulgación no autorizada.

También pueden establecerse disposiciones relacionadas con la propiedad de la información y la propiedad intelectual, los usos permitidos, la notificación de divulgaciones no autorizadas, la devolución o destrucción de la información cuando finalice el acuerdo y las acciones ante su incumplimiento. Los requisitos de estos acuerdos deberían revisarse periódicamente y cuando se produzcan cambios que puedan afectar a las necesidades de protección.

## 6.7 Teletrabajo

Este control es una medida de prevención que se ocupa de la gestión de activos, la protección de la información, la seguridad física y la seguridad del sistema y de la red.

Cuando el personal trabaja de forma remota, la organización debería implementar medidas de seguridad para proteger la información que se accede, procesa o almacena fuera de sus instalaciones. El teletrabajo comprende distintos entornos fuera de los locales de la

organización, incluyendo el trabajo desde el hogar, lugares públicos y otros espacios de trabajo remoto.

La organización debería establecer una política específica que determine las condiciones y restricciones del trabajo remoto. Entre los aspectos a considerar se encuentran la seguridad física del lugar de trabajo, el uso de redes domésticas y públicas, la seguridad de las comunicaciones, el acceso remoto, la información que puede manejarse y las amenazas derivadas de otras personas que puedan encontrarse en el entorno, como familiares, visitantes o personas presentes en lugares públicos.

También deberían contemplarse medidas como autenticación segura, cortafuegos, protección contra programas maliciosos, bloqueo de pantalla, temporizadores de inactividad y, cuando corresponda, seguimiento de ubicación y borrado remoto. La organización debería proporcionar formación y soporte al personal remoto, establecer procedimientos de copia de seguridad y continuidad y, cuando finalice el trabajo remoto, revocar las autorizaciones y derechos de acceso y recuperar los equipos correspondientes.

### Dispositivos móviles

En cuanto a la seguridad de los dispositivos móviles (celulares, tablets, netbooks, notebooks, etc.), esta no constituye un control independiente dentro del capítulo 6, pero está relacionada con las medidas de seguridad aplicables al teletrabajo y al uso de dispositivos fuera de las instalaciones de la organización. La protección debe contemplar los equipos utilizados para acceder, procesar o almacenar información de la organización, especialmente cuando se encuentran fuera de un entorno controlado.

Entre las medidas que pueden aplicarse se encuentran el bloqueo automático de pantalla, la autenticación segura, la protección contra programas maliciosos, la utilización de redes seguras, el control de los accesos y, cuando corresponda, la posibilidad de realizar un borrado remoto del dispositivo. También deben establecerse condiciones sobre qué información puede almacenarse o procesarse en estos equipos y qué hacer ante su pérdida, robo o compromiso.

## 6.8 Notificación de los eventos de seguridad de la información

Este control tiene la finalidad de detectar una infracción, trabaja sobre la gestión de eventos de seguridad de la información.

La organización debería proporcionar un mecanismo para que el personal pueda notificar oportunamente los eventos de seguridad de la información observados o sospechados mediante los canales correspondientes. El objetivo es permitir una notificación rápida, coherente y eficaz para prevenir o minimizar las consecuencias de posibles incidentes.

El personal debería conocer su responsabilidad de comunicar los eventos y saber cuál es el procedimiento y el punto de contacto correspondiente. El mecanismo debería ser sencillo, accesible y estar disponible para facilitar la notificación. Entre los eventos que pueden requerir comunicación se encuentran controles de seguridad ineficaces, incumplimientos de confidencialidad, integridad o disponibilidad, errores humanos, incumplimientos de políticas, accesos no autorizados, vulnerabilidades, comportamientos anómalos y sospechas de infección por código malicioso.

La norma también indica que el personal no debería intentar comprobar o explotar por su cuenta las vulnerabilidades sospechadas. Estas acciones pueden causar daños, alterar pruebas digitales o incluso generar responsabilidades legales. Por ello, ante una sospecha, la conducta adecuada es utilizar los mecanismos de notificación establecidos por la organización.

# Circulares

## Superintendencia de Riesgos del Trabajo (SRT)

En Argentina, existen resoluciones que tienen directrices internas y operativas estrictas alineadas a estándares como la ISO 27001 y la 27002. Una de ellas es la resolución 23/2023 de la Superintendencia de Riesgos de Trabajo (SRT). La SRT es el organismo encargado de supervisar el sistema de riesgos del trabajo en Argentina.

En ella se establecen pautas de comprobación de antecedentes, términos contractuales de responsabilidad, procedimientos disciplinarios e indisponibilidad/revocación inmediata de accesos ante el cese laboral. Como se observa, las pautas abarcan los controles 6.1, 6.2, 6.4 y 6.5, que desarrollaremos más adelante.

## ISO/IEC 27035 — Gestión de incidentes de seguridad

La ISO/IEC 27035 es una familia de normas orientada a la gestión de incidentes de seguridad de la información.

Mientras que la norma ISO/IEC 27002 establece los controles generales para reducir y gestionar riesgos —especificando, entre otros aspectos, que las personas deben estar preparadas para reportar eventos de seguridad—, la norma ISO/IEC 27035 complementa este marco al enfocar su alcance en el ciclo de vida completo del incidente. De este modo, profundiza en cómo la organización debe estructurarse operativamente para detectar, reportar, evaluar, responder y aprender de dichos eventos una vez que han sido notificados.

Su relación más directa, evidentemente, es con el control 6.8 (Notificación de los eventos de seguridad de la información).

## Superintendencia de Seguros de la Nación (SSN)

La SSN es el organismo que regula y supervisa la actividad aseguradora y, dentro de ese ámbito, establece requisitos que alcanzan a la gestión de información y a la seguridad de los sistemas de las entidades aseguradoras y reaseguradoras.

Los requisitos de ciberseguridad se relacionan con aspectos como gobierno de la información, gestión de accesos y control sobre empleados e intermediarios.

Se relaciona con el control 6.1, ya que establece que antes de incorporar una persona deben realizarse comprobaciones proporcionales al puesto, al riesgo y al tipo de información a la que tendrá acceso.

Los requisitos sobre responsabilidades y perfiles de acceso se pueden relacionar con 6.2 porque este control exige que el personal conozca formalmente sus responsabilidades de

seguridad de la información y la SSN establece un marco de control sobre las personas y sus accesos.

Las directrices contemplan programas continuos de concientización, esto encaja directamente con el control 6.3, que exige capacitación y actualización periódica adaptada a las responsabilidades de cada persona.

Los acuerdos de confidencialidad mencionados para el sector asegurador se relacionan directamente con 6.6. ISO establece que estos acuerdos deben definir qué información se protege, durante cuánto tiempo, qué responsabilidades tienen las partes y qué ocurre ante una divulgación no autorizada.

## AAIP — Ley 25.326 de Protección de Datos Personales

Esta es probablemente una de las relaciones más interesantes, porque introduce una obligación legal que complementa varios controles de ISO 27002.

La Ley 25.326 establece el régimen de protección de los datos personales y regula aspectos relacionados con su tratamiento y seguridad.

El artículo 9 se puede relacionar con varios controles porque exige adoptar medidas de seguridad para proteger los datos personales frente a accesos, alteraciones o usos no autorizados. Esto complementa el enfoque de ISO 27002, ya que el capítulo 6 busca reducir el riesgo generado por las personas que tienen acceso a información.

En resumen, la norma ISO 27002 establece controles organizativos sobre las personas y la Ley 25.326 agrega una obligación legal específica cuando la información involucrada son datos personales.

Existe una clara sinergia entre las prácticas recomendadas de la norma y el marco regulatorio argentino sobre la confidencialidad. Por un lado, la ISO/IEC 27002 establece en el control 6.5 que las obligaciones de reserva deberían perdurar tras el cese laboral, mientras que el control 6.6 exige formalizar estos compromisos mediante acuerdos de confidencialidad o NDA. Por otro lado, este principio técnico encuentra su respaldo jurídico en el Artículo 10 de la Ley N° 25.326 de Protección de Datos Personales, el cual impone al personal la obligación legal de guardar secreto profesional sobre los datos tratados, un deber que subsiste obligatoriamente aún después de finalizada la relación laboral.

## Ley 27.555 — Régimen Legal del Teletrabajo

La Ley N° 27.555 constituye el marco legal fundamental del teletrabajo en Argentina, regulando las condiciones de la relación laboral cuando las tareas se realizan fuera del establecimiento del empleador. Esta normativa contempla aspectos laborales y operativos críticos, tales como la provisión y mantenimiento del equipamiento, la protección de la información, el derecho a la desconexión digital y los límites estrictos sobre las facultades de control y monitoreo del empleador.

Esta regulación jurídica se complementa directamente con el control 6.7 (Trabajo remoto) de la norma ISO/IEC 27002, el cual exige a la organización diseñar e implementar directrices específicas para salvaguardar la información a la que se accede, procesa o almacena fuera de las instalaciones corporativas.

Ambos marcos normativos se potencian de manera directa al abordar el teletrabajo desde perspectivas diferentes pero interdependientes. Mientras que la ISO/IEC 27002 (Control 6.7) plantea la interrogante de cómo proteger técnicamente los activos de información en entornos remotos (mediante cifrado, accesos virtuales seguros o borrado a distancia), la Ley 27.555 responde a qué derechos y garantías laborales deben respetarse durante dicho proceso. De esta forma, la ley laboral fija las fronteras éticas y legales para la aplicación de los controles de seguridad: por ejemplo, la norma ISO promueve la auditoría y monitoreo del acceso remoto, pero la Ley 27.555 restringe dichos controles garantizando la privacidad del trabajador y limitando el monitoreo a software de protección exclusivo para el trabajo, sin invadir su vida privada ni vulnerar su derecho a la desconexión.

## Ley 20.744 — Ley de Contrato de Trabajo

La Ley de Contrato de Trabajo (LCT) establece el marco general de las relaciones laborales en Argentina, permite relacionar las obligaciones laborales generales del trabajador con las responsabilidades específicas de seguridad de la información.

El control 6.2 exige que las responsabilidades de seguridad estén formalmente establecidas en los términos de empleo y la LCT proporciona el marco jurídico laboral general dentro del cual se establecen esas obligaciones.

También puede relacionarse con el proceso disciplinario, porque el control 6.4 exige que las medidas frente a incumplimientos consideren los requisitos legales y contractuales aplicables, y la LCT establece el marco laboral que debe respetarse al aplicar esas medidas.

## Ley 26.388 — Delitos Informáticos

La Ley 26.388 modificó el Código Penal argentino para incorporar y actualizar figuras vinculadas con delitos informáticos. Su relación con el capítulo 6 es un poco diferente a las anteriores, no establece un control de seguridad de recursos humanos, sino que establece consecuencias jurídicas para determinadas conductas, por ejemplo, puede ser relevante frente a conductas como el acceso ilegítimo a sistemas, determinadas violaciones de secretos o daños/alteraciones de información.

Esto puede relacionarse con:

- El control 6.2 de términos de empleo porque las personas deben conocer sus responsabilidades legales y las consecuencias de determinadas conductas.
- El control 6.4 de proceso disciplinario porque una conducta puede constituir simultáneamente un incumplimiento de una política interna, una infracción laboral y, dependiendo del caso, un delito.

Esto es importante para explicar que el proceso disciplinario interno no reemplaza las consecuencias legales externas.

## Dirección Nacional de Ciberseguridad / ONTI

Las directrices de ciberseguridad para la Administración Pública constituyen un marco de referencia para establecer prácticas de seguridad dentro del ámbito estatal.

Lo más importante es la relación con el control 6.3 de concientización, educación y formación, que establece que la organización debe implementar un programa periódico de capacitación, proporcionar formación inicial y actualizar los conocimientos del personal según sus responsabilidades. Además, la capacitación debe abordar las políticas, procedimientos, responsabilidades, notificación de eventos y riesgos como el phishing.

## BCRA - COMUNICACIÓN "A" 2659

La Comunicación “A” 2659 del Banco Central de la República Argentina (BCRA), de 1998, aprobó los “Requisitos operativos mínimos del área de sistemas de información (SI)” aplicables a las entidades financieras y cámaras de compensación de fondos. La norma establece requisitos mínimos que debían cumplir estas entidades y cuya aplicación quedaba sujeta a supervisión de la entonces Superintendencia de Entidades Financieras y Cambiarias.

Su objetivo general es establecer un nivel razonable de seguridad y control sobre los sistemas de información. La norma contempla expresamente aspectos de confidencialidad, integridad, disponibilidad, cumplimiento y confiabilidad, y aclara que estos principios deben aplicarse a todos los recursos involucrados en los procesos informáticos, incluyendo datos, sistemas, tecnología, instalaciones y personas.

Es decir, no se limita a cuestiones técnicas. También establece requisitos relacionados con las personas, sus funciones, responsabilidades, accesos, autenticación, separación de funciones, proveedores y desvinculación. Por eso tiene varias conexiones interesantes con el capítulo 6 de ISO/IEC 27002.

### Relación con el control 6.2

La Comunicación A 2659 establece que deben existir políticas generales y una definición clara de las misiones y funciones de todos los puestos de trabajo, incluyendo responsabilidades, dependencia y funciones supervisadas. Además, exige estándares y procedimientos escritos que sirvan como base para la planificación y el control del área de sistemas. Esto se relaciona con el control 6.2 de ISO 27002, que establece que los acuerdos de empleo deben especificar las responsabilidades del personal y de la organización respecto de la seguridad de la información.

La diferencia es interesante, BCRA A 2659 exige que estén definidas las funciones, responsabilidades y dependencias de los puestos del área de sistemas, y la ISO 27002 6.2 lleva esa formalización específicamente al ámbito de las responsabilidades de seguridad de la información dentro de la relación laboral.

### Relación con el control 6.4

La Comunicación A 2659 se relaciona con el proceso disciplinario porque exige que la política de seguridad informática contemple cursos de acción ante sumarios a empleados. Esto complementa al control 6.4 de ISO 27002, que establece formalmente la necesidad de un proceso disciplinario frente a incumplimientos de seguridad.

## Relación con el control 6.5

La “A” 2659 exige que la política de seguridad informática contemple expresamente los cursos de acción ante la desvinculación de empleados o terceros. Esto encaja directamente con 6.5, donde ISO establece que las responsabilidades y obligaciones de seguridad que continúan después de una finalización o cambio deben estar definidas, comunicadas y aplicadas. También contempla la gestión de los cambios de puesto.

Además, la A 2659 tiene un elemento todavía más concreto: exige mecanismos relacionados con el acceso de los usuarios y la administración de sus claves, dentro de la política de seguridad.

## Relación con el control 6.6

Aunque la Comunicación "A" 2659 del BCRA enfatiza la protección de la confidencialidad mediante controles sobre el uso no autorizado de datos, claves y accesos, no debe interpretarse como una norma que imponga acuerdos de confidencialidad (NDA). El control 6.6 de la ISO/IEC 27002 va un paso más allá en términos contractuales, ya que exige definir explícitamente qué información se protege, la vigencia del compromiso, el destino final de la información y las responsabilidades legales asociadas. Por este motivo, la regulación del BCRA puede citarse como un antecedente de resguardo de la información, pero no como una exigencia legal de acuerdos de no divulgación.